Data Privacy and Compliance for LLMs

skyflow

Contents

3 Introduction

4 Learning from Early LLM Adoption Headaches

A Deeper Look at LLM Privacy and Compliance Challenges

LLM Adoption Challenges Posed by Data Privacy Laws

7 Protecting Sensitive Data with a Data Privacy Vault

De-identifying Sensitive Data for LLMs

Privacy-preserving Model Training

Multi-party Model Training

Data Residency and Compliance

11 Why You Need a Vault-based AI Privacy and Compliance Strategy

12 LLM Data Privacy for Healthcare Decision Support

13 Conclusion

skyflow

Introduction

The rapid rise of ChatGPT and Large Language Models (LLMs) is raising data privacy concerns with businesses and regulators. Meanwhile, businesses of all sizes are weighing a variety of tradeoffs as they ask questions like:

- *How quickly can we use LLMs in our core workflows, including those that involve sensitive data?*
- *Where does it make sense to use LLMs, and where should we be more cautious?*
- *How can we balance the need to adopt LLMs to stay competitive against the need to protect our business and our customers?*

Fortunately, while the booming adoption of LLMs is new, businesses can use another technology that's already mature to help them navigate these concerns and unblock the adoption of LLMs: the data privacy vault.

In this white paper, we'll look at what we can learn from early LLM adoption headaches, the compliance challenges facing LLM adopters, and why every company needs an AI privacy strategy. We'll also look at the need to prevent sensitive data from entering LLMs with a data privacy vault, how using a vault addresses compliance concerns like data residency and HIPAA compliance while unblocking LLM adoption, and where a vault fits into your architecture.

Learning from Early LLM Adoption Headaches

Recent events have brought these concerns to the forefront of business leaders' minds, including:

- Samsung's recent ban on ChatGPT due to worries about leaks of internal documents and data
- Italy's initial prohibition (subsequently lifted) on the use of ChatGPT
- Survey results indicating that bans aren't always effective (while 32% of respondents say their organizations have banned the use of generative AI, only 5% say employees never use generative AI)

At the same time, companies face ongoing challenges as they seek to comply with data privacy regulations. For example, Meta (formerly Facebook) was recently slapped with a hefty $1.4 billion fine by the European Union for transferring personal data to the U.S. The fine against Meta is a sign of growing momentum in EU data privacy fines, as businesses operating in Europe were fined a total of $1.2 billion in 2021 for violating the General Data Protection Regulation (GDPR).

As enterprises shape their AI strategies and invest in LLMs, prioritizing privacy considerations has become more crucial than ever. LLMs introduce a paradigm shift in how applications function, and they operate in a fundamentally different manner than traditional information systems. Unlike conventional applications, LLMs have an indelible memory and lack a straightforward mechanism to "unlearn" specific information. There is no practical "delete" button for sensitive data stored within an LLM. And "retraining" a model just to delete a few bytes of data, such as a former customer's PII, is expensive, inefficient, and so time-consuming as to be impractical.

A Deeper Look at LLM Privacy and Compliance Challenges

Whether you're utilizing tools like ChatGPT or developing your own generative AI systems, privacy poses a significant challenge. Products such as ChatGPT cannot guarantee data privacy, presenting a particularly daunting hurdle for businesses that require strict privacy and confidentiality measures.

Consider what would happen if sensitive contract information were copied and pasted into an LLM that trains itself using user conversation data. The user might get assistance with their immediate need, but the sensitive data from that contract has passed beyond the user's control. Many LLM providers promise that they don't use information gleaned in conversations with users to update their models, but they could use that data to train other models with that information, making it available to other users of the LLM. In any case, after you provide sensitive data to an LLM, whether it's public or private, you can't delete that data, and you can't predict how that data could be used (or misused) in the future. The only solution is to keep sensitive data out of the LLM.

Data privacy and compliance require companies to protect sensitive data, including internal company project names, dates of birth, social security numbers, or healthcare information. Unless you're careful, this data can find its way into LLMs in a variety of ways, including:

- **Training Data:** LLMs are trained on vast datasets that may contain personally identifiable information (PII). If proper anonymization or redaction measures are not applied, sensitive data enters the model during training and could potentially be exposed later. Model training is expensive and resource intensive, so "retraining the model" isn't a viable way to delete sensitive data that's exposed to LLMs during training.

- **Inference from Prompt Data:** LLMs generate text based on user input or prompts. Similar to training data, if the prompt includes sensitive data, it could potentially be logged or stored, and be used to train future versions of that model, potentially influencing the model's generated content, and potentially exposing this sensitive data.

- **Inference from User-Provided Files:** Beyond simple text prompts, LLM-based AI tools allow users to provide documents or other files that might contain sensitive data. These files are processed by LLM-based AI systems such as chatbots, translation tools, or content generators. Similar to prompt data, the sensitive information within these files could be used to train future versions of that model or be exposed during content generation due to a lack of built-in data governance in the LLM.

So, why not just use a private LLM? Beyond cost considerations, using a private LLM doesn't solve the issue of data governance.

This is because, unlike a traditional software application database where you can control data access by restricting which rows and columns a user has access to, with an LLM, data isn't structured in rows and columns that you can govern discreetly with fine-grained access controls. This means that traditional methods for data governance, which focus on protecting data after it's stored in a relational database, can't be applied to LLMs.

While LLMs offer exciting possibilities for businesses, these issues require proactive solutions that you should implement before adopting LLMs for any workload that involves sensitive data. To unblock LLM adoption, businesses need to address their own data privacy concerns (and those of their customers) while being mindful of the data privacy and protection laws in the markets where they operate - and in markets where they hope to expand.

As you'll see in the next section, this lack of data governance is a major problem, whether you're looking to protect sensitive data from data breaches or whether you need to comply with a data privacy law like the EU's GDPR.

LLM Adoption Challenges Posed by Data Privacy Laws

Data privacy regulators across the globe are struggling to keep up with the rapid pace of technological innovation, especially innovations around LLMs and other forms of AI. Certain provisions of existing regulations, like the "right to be forgotten" found in the EU's GDPR, present challenges for LLMs in various jurisdictions, including not only the European Union, but also Argentina, the Philippines, and California.

This is due to one of the major drawbacks of LLMs that we mentioned above: their inability to selectively remove (or "unlearn") individual data points such as an individual's name or date of birth. This limitation creates long-term compliance risks for businesses utilizing LLMs, especially in the areas of handling data subject requests, managing data localization and data residency, and protecting sensitive healthcare data in decision support systems.

- **Data Subject Request (DSR) Compliance:** Many data privacy laws, such as the EU's GDPR, grant individuals the right to access, rectify, and erase their personal data - which can be very difficult to accomplish if that data is found within an LLM. LLMs are often distributed across multiple servers, which makes identifying and extracting the specific data associated with an individual arduous and error-prone. If you get a request to erase sensitive data, known as a "right to be forgotten" request, you won't be able to honor it without retraining your model if that individual's sensitive personal data exists in that model.

- **Automated Decision-making Compliance:** GDPR also grants individuals the right to object to automated decision-making that involves their sensitive data, which can be difficult to guarantee if that data finds its way into an LLM. With GDPR being an influential law that many other nations look to for inspiration when drafting

their legislation, provisions like this could likely show up in future data privacy laws in other markets, creating headaches for companies that aren't careful to keep sensitive data out of LLMs.

- **Data Localization and Data Residency Compliance:** Complying with data localization and data residency requirements that restrict where sensitive data can be stored and processed becomes nearly impossible when using a global LLM. For example, meeting the stringent conditions of China's Personal Information Protection Law (PIPL) regarding the transfer of personal information outside of China poses significant difficulties if this information is present in an LLM that a company uses for all of its global customer base.

Considering the complex and ever-changing privacy and compliance landscape and the complexity of LLMs, the most practical approach to maintaining compliance is to prevent sensitive data from entering any LLMs that you're using altogether. But if you don't approach this the right way, doing this could limit their usefulness and ROI for your business.

So, what's the solution? Using a data privacy vault. Data privacy vaults help to preserve privacy by isolating, protecting, governing, and localizing access to sensitive data. When coupled with LLMs, a data privacy vault protects the privacy of sensitive information throughout the entire lifecycle of these models, empowering businesses to harness the full potential of LLMs without compromising on data privacy.

Protecting Sensitive Data with a Data Privacy Vault

A data privacy vault acts as a secure repository for sensitive data that keeps it safe from unauthorized access and eases compliance with data privacy regulations - without sacrificing data utility. You can think of a data privacy vault as a firewall for sensitive data, except whereas a corporate network firewall keeps viruses and bad actors out of your intranet, a data privacy vault keeps sensitive data isolated, protected, and governed - and out of LLMs and other infrastructure.

This effectively takes your LLMs and other systems out of the scope of compliance and data security concerns. That's why the data privacy vault architectural pattern has been recognized as a best practice for handling sensitive data by organizations like the IEEE.

So, how do data privacy vaults work?

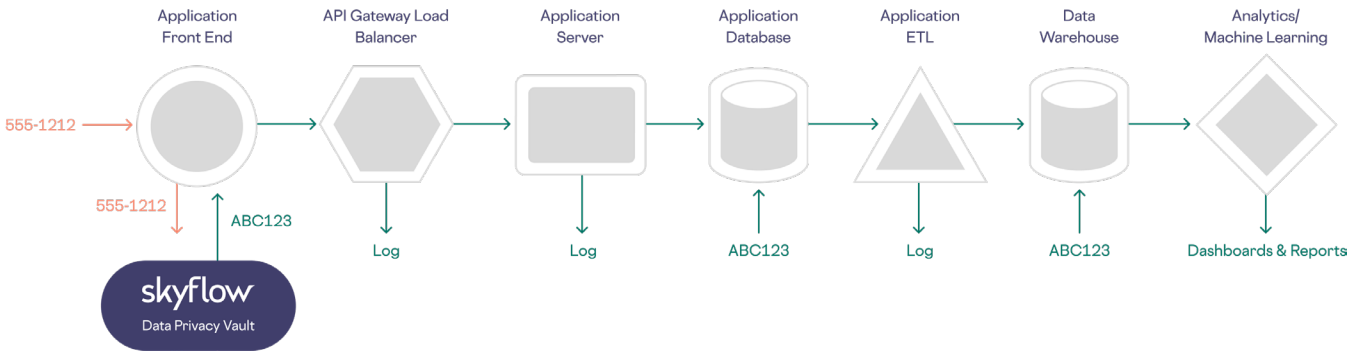
A Simplified Example: Isolating Sensitive Data with a Data Privacy Vault

Before we dig into using a data privacy vault with LLMs, let's look at how it works with a more typical cloud-based architecture.

In the example architecture shown below, a phone number is first collected by a front end application. This phone number (or any other PII) is stored securely in the vault, which is isolated outside of your company's existing infrastructure.

Outside of the vault, downstream services like application databases, data warehouses, logs, etc. store vault-generated tokens - obfuscated values that act as "stand-ins" for sensitive data elements like names, phone numbers, etc. Note that vault-generated tokens are distinct from LLM tokens that are used to chunk and process data during model training, and used again when LLMs generate responses.

Because downstream services only store vault-generated tokens, those systems are removed from the scope of compliance, as shown in the diagram below, where the phone number "555-1212" is tokenized as "ABC123":



An Architecture that Reduces Compliance Scope with a Data Privacy Vault

As you can see, a data privacy vault not only decreases your scope of compliance, it also improves auditability because the vault provides a single source of truth where you can log all sensitive data access and use. A data privacy vault is

highly interoperable, meaning that you can use a vault to protect any type of data, across databases and CRMs, rather than only solving privacy and compliance issues within a particular cloud platform.

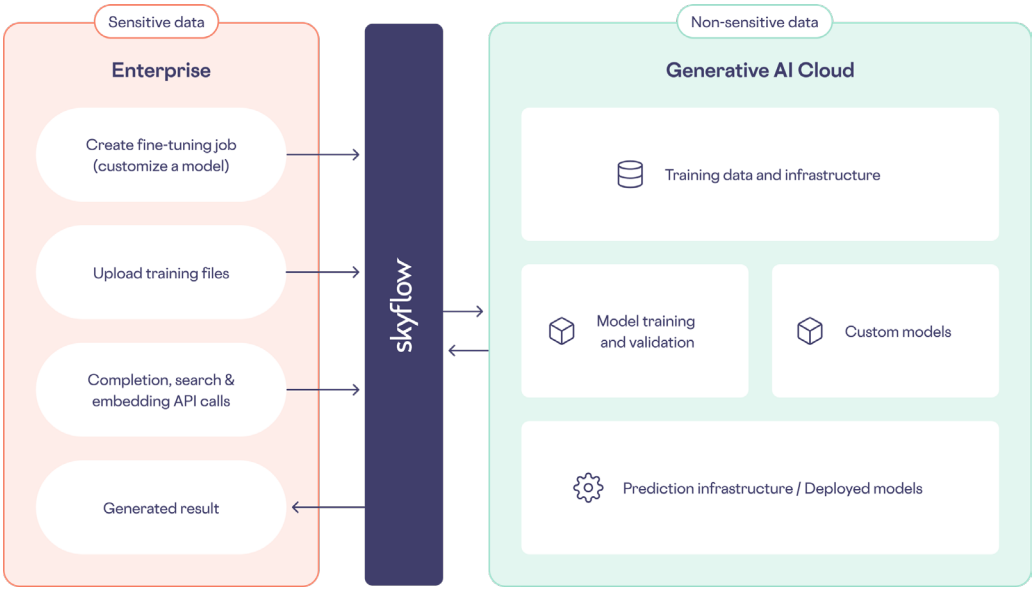
De-identifying Sensitive Data for LLMs

In the context of LLMs, the same approach can be used to prevent the leakage of sensitive data and simplify compliance. As we'll show below, de-identified data is swapped with tokens as part of the data collection process, and these tokens are passed along and stored within traditional application systems like databases and various logging systems.

A data privacy vault detects sensitive data elements and prevents those data elements from leaking into LLMs - either by redacting them completely or converting them into non-sensitive deterministic tokens that act as "stand-ins" for the plaintext sensitive data.

Because the tokens are deterministic, a given sensitive data value will consistently tokenize into the same string, so the LLM can handle the vault-generated tokens the same way it handles any text input - and the same way that it would handle plaintext sensitive data. Again, these tokenized values are distinct from LLM tokens used to chunk and process information within an LLM.

This approach can be applied to datasets used for model training and also used to protect sensitive data included in prompts, files, or other content that users provide to an LLM, as discussed below.



How Skyflow LLM Privacy Vault Integrates with Your LLM Toolchain

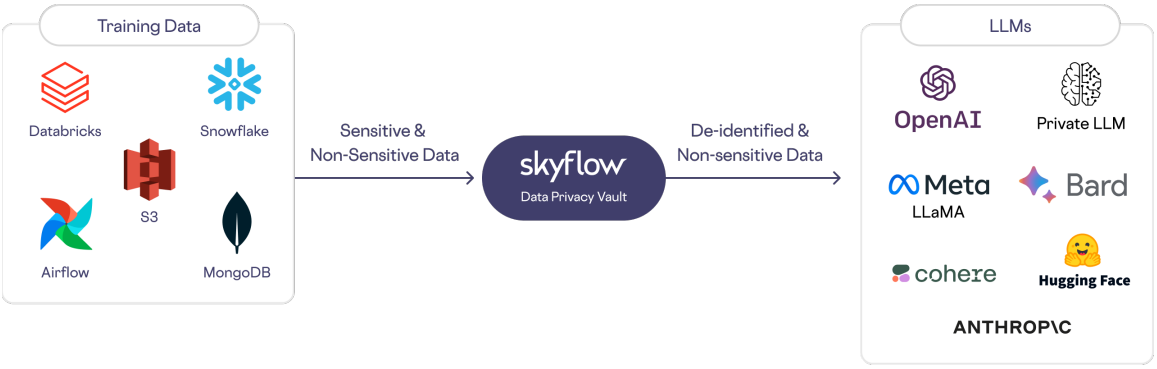
Privacy-preserving Model Training

LLMs are typically trained on large amounts of data. Without proper safeguards, it's easy for sensitive PII or other sensitive data to leak into a model training dataset.

To address this potential risk, all training data should flow through a data privacy vault, which acts as a firewall for sensitive data - first, it's detected, and then it's stored within the vault. Skyflow filters out plaintext sensitive data from

the training dataset during data ingress to prevent this data from reaching LLMs during model training.

With plaintext sensitive data stored in Skyflow, LLM training can proceed as normal, with a dataset that is de-identified and privacy-safe.

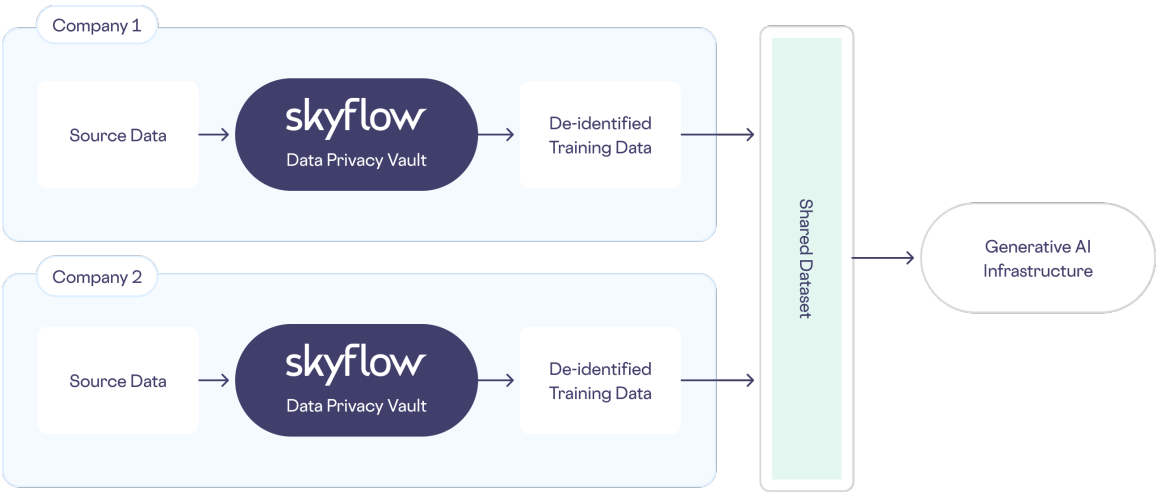


Using Skyflow to De-Identify Sensitive Data During LLM Training

Multi-party Model Training

Multi-party training occurs when multiple parties (i.e., companies) pool data into a shared dataset for purposes of model training. With Skyflow LLM Privacy Vault, you can do more than de-identify sensitive data to prevent its inclusion in shared model training datasets. Skyflow also lets you define which types of information are sensitive using custom definitions so that you can protect the privacy and security of proprietary data and keep that data out of shared datasets - and out of shared LLMs.

For example, let's say that your company is running a joint venture with another company. The joint venture will need to use a shared LLM that's trained on a shared dataset. But, both you and your joint venture partner need to protect sensitive data like internal project names and customer PII. You can use an architecture like the following to support multi-party model training without exposing sensitive data:



Using Skyflow to De-Identify Sensitive Data During Multi-party Model Training

When an LLM generates a response, vault-generated deterministic tokens can be detokenized as the response is sent to the user, replacing these tokens with the original sensitive data elements or masked data, depending on the access control policies. Only authorized users are permitted to detokenize the sensitive data, giving each business fine-grained access control over the data stored in the data privacy vault.

This lets both companies in the joint venture share a de-identified dataset while retaining data governance for PII and other sensitive data that are isolated in their respective vaults.

Data Residency and Compliance

With a data privacy vault approach, the sensitive data that are subject to regulation under laws like GDPR and Brazil's LGPD are restricted to the vault, so that data can be kept in a specific location. To satisfy data residency requirements (or avoid the legal uncertainty associated with cross-border data transfers), you can place multiple regional vaults near customers whose data is subject to these requirements. This is simpler, easier to maintain, and less expensive than geo-replicating your entire infrastructure in each region, as TikTok has done.

With sensitive data now stored in data privacy vaults, it no longer matters if you operate a single global LLM because data residency concerns no longer apply to the model. Compliance with data residency requirements now depends solely on where your data privacy vaults are located. All sensitive data goes into the data privacy vaults, and these vaults become the only component of the architecture subject to data residency requirements.

With a vault, you can also address other compliance challenges like honoring GDPR's "right to be forgotten" much more easily. Because sensitive customer data is now stored in the vault, which is the single source of truth for personal data, the only location where you need to delete a customer's data is the vault. After the sensitive data is removed from the vault, the vault-generated tokens used within the LLM or other systems are meaningless, and can't be reverse-engineered to retrieve the underlying personal data.

Similarly, the vault simplifies data subject requests because a business leveraging LLMs with a data privacy vault has a single source of truth for customer data, so it's easy to understand what data they're storing about a given user and how it's being used.

Why You Need a Vault-based AI Privacy and Compliance Strategy

Companies need data privacy and security throughout the entire data lifecycle, including the LLM lifecycle – from data collection to model training and inference.

A data privacy vault provides architectural solutions for sensitive data. With a data privacy vault, sensitive data is:

- ***Isolated* from the point of ingestion or storage:** Data privacy vault APIs or SDKs allow the collection of sensitive data and isolate it in a vault that's separated from other systems, reducing the scope of compliance.
- ***Protected* through multiple types of data obfuscation:** Data protection goes beyond isolating and encrypting sensitive data in a vault. Effective data protection supports secure workflows that can include trusted third party services, custom logic, and the ability to run analysis on sensitive data without compromising data privacy.
- ***Governed* using fine-grained access controls:** With fine-grained access controls, it's easy to govern sensitive data access so that only the right people get access to the right data at the right time.
- ***Localized* using regional vault instances:** With sensitive data isolated from a company's other systems, it's easy to store it in regional vaults without the need to replicate infrastructure instances in each region.

These capabilities are why over a hundred companies, including giants like Netflix and Apple and Skyflow customer Lenovo, are using data privacy vaults in production today.

So, how does this work with LLMs? A data privacy vault should sit between your data sources – training data, fine-tuning data, inference data – and your LLM, machine learning, and other infrastructure.

Here's an overview:

- **Detect and protect:** A data privacy vault detects and protects sensitive data to prevent it from ending up in LLMs or machine learning tools, allowing you to use these tools without data privacy concerns. This detection can be based on identifying sensitive data types by their structure (as with SSNs) or using a company-defined sensitive data dictionary.
- **Isolate sensitive data:** A vault isolates and stores sensitive data and provides pseudonymized "stand-ins" (i.e., vault-generated tokens) to LLMs. This means that LLMs only interact with these tokens, keeping sensitive data secure. Alternatively, a vault lets you completely redact sensitive data (instead of tokenizing it) to keep it out of LLMs.
- **Re-identify sensitive data in model outputs:** When LLMs provide output data, a data privacy vault can swap vault-generated tokens for plaintext sensitive data elements, like a name or date of birth, safeguarding user data privacy without affecting the user experience. Of course, any access to sensitive data is subject to strict zero trust controls configured in the vault that restrict plaintext sensitive data to only authorized users, processes, and workloads.
- **LLM is unaffected by data audits and deletion requests:** With sensitive data stored in a zero trust data privacy vault, you can create audit logs and delete sensitive data to ease compliance with data privacy laws and standards. Because sensitive data is only stored in the vault, not your LLM, there is no need to take your LLM offline or retrain it to handle audits or right-to-be-forgotten requests under regulations like GDPR.

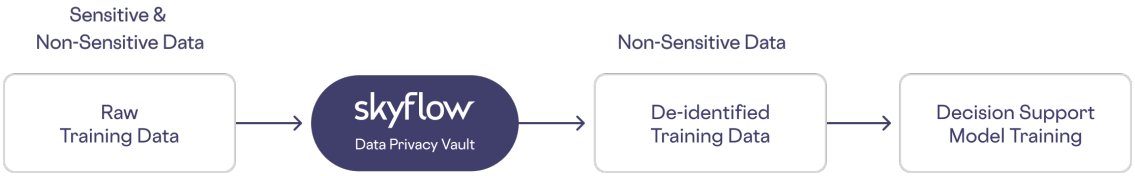
So, now that we know the benefits of isolating sensitive data in a vault, let's take a closer look at how we can use a vault to prevent sensitive healthcare data from entering LLMs.

LLM Data Privacy for Healthcare Decision Support

To illustrate the practical applications of a data privacy vault, let's consider the healthcare industry, where data privacy is regulated by laws like HIPAA in the United States, and similar laws internationally.

Let's say that you need to aggregate unstructured data, like doctor's notes in patient healthcare records, to train an LLM model that will provide a decision support system for healthcare providers. To do this, you can detect and de-identify sensitive data with a vault and then feed de-identified data into an LLM for training purposes.

A HIPAA-compliant data privacy vault makes this easy because all identifying details (PHI) are kept out of the LLM. After the model is trained, you can continue to use the data privacy vault to prevent sensitive data from entering the model during inference. Sensitive identifying information is detected and stored in the vault, so only de-identified data makes its way to the LLM, as shown below:



Using Skyflow to De-Identify Sensitive PHI During Model Training

Conclusion

A data privacy vault gives you effective data privacy and protection across your infrastructure and systems, and throughout the entire lifecycle of LLMs:

- **Data Privacy and Security:** A data privacy vault provides a secure environment for sensitive data, protecting it from unauthorized access, breaches, and data leaks
- **Compliance with Regulatory Requirements:** Global companies can leverage AI while complying with auditing and data residency requirements, such as those found in laws like GDPR, LGPD, and others
- **Granular Data Control:** Organizations can maintain strict control over sensitive data so that only authorized individuals or entities can access specific data sets or functionality within LLM-based AI systems, and so that access is limited to only the specific data that a workflow requires
- **Privacy-Preserving AI:** Sensitive data is redacted and anonymized during data collection, model training, and interactions, empowering organizations to maximize utility without compromising privacy

As enterprises look to invest in generative AI, protecting data privacy in the models is essential to help ensure the technology is used in a responsible, ethical, and compliant manner. By using a data privacy vault as their end-to-end privacy solution for generative AI, companies can protect the privacy and security of sensitive data, protect user privacy, and retain user trust when using LLMs.

Ready to see it yourself?

Contact us to get an LLM Privacy Vault demo.

About Skyflow

Skyflow is a data and AI privacy company built to radically simplify how companies isolate, protect, and govern their customers' most sensitive data. With its global network of data privacy vaults, Skyflow is also a comprehensive solution for companies around the world looking to securely implement LLMs and meet complex data localization requirements. Skyflow currently supports a diverse customer base that spans verticals like fintech, retail, travel, and healthcare.

Skyflow is headquartered in Palo Alto, California and was founded in 2019.
For more information, visit skyflow.com or follow us LinkedIn and X.

skyflow

© 2023 Skyflow, Inc. All rights reserved.